ISO/IEC 27001 | LABORATORIO LEAD IMPLEMENTER

CloudPay ISMS Operating Model

Modello operativo del Sistema di Gestione per la Sicurezza delle Informazioni

---

DOCUMENTO	CONTESTO
Documento di laboratorio	Fintech

Struttura del documento

Il modello descrive il ciclo operativo dell'ISMS, assegna la responsabilità delle singole fasi e rende espliciti i collegamenti necessari tra rischi, controlli, evidenze, audit e miglioramento.

Uso previsto: esercitazione Lead Implementer basata sui riferimenti ISO/IEC 27001 indicati.

1. Ciclo operativo

Il ciclo collega le attività di definizione del contesto alla valutazione e al trattamento dei rischi, all'attuazione dei controlli e alla verifica del sistema. Il miglioramento riporta il processo al contesto.

01	**Contesto**	Cl. 4.1
02	**Ambito**	Cl. 4.3
03	**Valutazione del rischio**	Cl. 6.1.2
04	**Trattamento del rischio**	Cl. 6.1.3
05	**Controlli**	Cl. 8 / Allegato A
06	**Evidenze**	Registro delle evidenze
07	**Audit interno**	Cl. 9.2
08	**Riesame della direzione**	Cl. 9.3
09	**Miglioramento**	Cl. 10

Ritorno del ciclo: dopo il miglioramento, il processo torna al contesto.

2. Responsabilità delle fasi

Fase	Responsabilità e modalità
Contesto	CISO. Aggiornamento annuale e in caso di cambiamenti rilevanti del business.
Ambito	CISO, con approvazione del CEO.
Valutazione del rischio	CISO con i responsabili delle funzioni. Cadenza trimestrale.
Trattamento del rischio	Responsabili del rischio nominati per ciascun rischio.
Controlli	Responsabili assegnati a ciascun controllo. Monitoraggio nel registro dei controlli.
Evidenze	Responsabili dei controlli. Conservazione nel registro delle evidenze.
Audit interno	Funzione indipendente. Almeno annuale.
Riesame della direzione	Presieduto dal CEO. Semestrale.
Miglioramento	Il responsabile dell'ISMS monitora il registro CAPA.

3. Collegamenti critici tra le fasi

I collegamenti trasversali assicurano tracciabilità e continuità tra il registro dei rischi, i controlli applicabili, le evidenze raccolte, gli audit e le decisioni della direzione.

01	**Rischi → Controlli** Ogni controllo dell'Allegato A applicabile fa riferimento ad almeno un rischio nel registro.
02	**Controlli → Evidenze** Ogni controllo dispone di un riferimento alle evidenze nel registro delle evidenze.
03	**Audit → CAPA → Riesame** Ogni rilievo di audit interno alimenta il registro CAPA e il successivo riesame della direzione.
04	**Riesame → Obiettivi e rischi** Ogni riesame della direzione produce decisioni che aggiornano gli obiettivi e i rischi.

4. Punteggio diagnostico

100%

Accuratezza del flusso

9 collegamenti su 9 rappresentati correttamente

Esito riportato: il flusso operativo è stato rappresentato con tutti i 9 collegamenti corretti.